



QA and engineering *review.*

Every page, link and form for all three roles, plus a code review of the money, authorisation and error paths. Thirteen issues found and fixed, and the four product gaps the review raised (rate limiting, account closure, admin two-factor, HTML email) built and tested the same day. All suites green.

QA report

For the founder and team

4 October 2026

Version 1.1

Build

Production, local Supabase

Scope: every page, link, navigation element and form of the web app, for all three roles, plus a code review of the money, authorisation and error-handling paths. Done against a production build (`next build && next start`) on a local Supabase.

What was run

CHECK	METHOD	RESULT
Site crawl: every internal link reachable from each role's pages (public 25, creator 40, researcher 55, admin 51 pages)	Playwright crawler: HTTP status, error pages, console errors, broken images, missing <code>alt</code> , unlabeled fields, controls without a name, <code>h1</code> count, horizontal overflow, empty links, <code>target=_blank</code> without <code>noopener</code> , missing meta description, duplicate/weak titles, nav active state, mobile drawer	0 broken links, 0 error pages, 0 overflow; findings below
Href-to-route audit	Every <code>href</code> in the code compared with the <code>app/</code> tree	All targets exist
Behaviour probes	XSS strings in titles, 3,000-char text without spaces, emoji and 6,000-char instructions, numbers with commas/spaces, triple-click on Confirm unlock, time-zone rendering for a Manila viewer, notification badge, payout-method removal, <code>?next=</code> open-redirect attempt	9 / 9 pass after fixes
Scripted browser suites (<code>npx playwright test</code>)	Full marketplace flow; swipe file → shortlist/pass → idea board → results → invites	2 / 2 pass
Exploratory run (<code>tests/e2e/exploratory.mjs</code> , 34 steps)	ID upload and review, proof screenshots, every pitch rule, disputes end to end, payouts, suspension, admin pages, cross-role access, phone sweep	34 / 34 pass
Unit and database suites	<code>npm test</code> , <code>npm run db:test</code>	16 / 16, all pass
Code review	middleware, actions, routes, RLS, SQL functions, payments, headers	findings below

Bugs found and fixed (all in this commit)

#	SEVERITY	PROBLEM	FIX
1	P1	Long text widened the whole page. A description, message or instruction with a long unbroken run (a pasted URL, a hashtag string) stretched the page to 24,000 px sideways.	Global <code>overflow-wrap</code> : anywhere on content containers. Verified with a 3,000-char and a 6,000-char input.
2	P1	Valid pitches were rejected. Browsers submit textarea line breaks as <code>\r\n</code> , so a 5,990-character write-up with 140 line breaks arrived as 6,130 characters and hit the database's 6,000 limit, while the form's own counter said it was fine. Same for every textarea in the app.	Every server action normalises <code>\r\n</code> to <code>\n</code> before validation.
3	P1	Vague validation error. Any length-limit failure said "Some fields are too short or too long", so the researcher could not tell which of eight fields to fix.	The message now names the field ("Instructions: too short, too long or in the wrong format...") and the raw constraint is logged.
4	P1	Times shown in the server's time zone with no label. "Reply by Oct 3, 2:19 PM" on a dispute was UTC; a researcher in Manila would read it 8 hours early. 15 places.	New <code><When></code> component renders every time with a date in the viewer's own time zone (server renders UTC with a label, browser replaces it).

#	SEVERITY	PROBLEM	FIX
5	P2	Notification badge never cleared unless the person pressed "Mark all as read".	Viewing the notifications list marks them read; the list still highlights what was unread.
6	P2	Silent failures in Wallet. Removing a payout method while a withdrawal to it was pending did nothing, with no message; cancelling a withdrawal gave no confirmation.	Both now return a message or confirm at the top of the page (the row disappears, so the confirmation can't live on it).
7	P2	No page titles on dynamic pages. Public researcher profiles, briefs, disputes, conversations and creator onboarding all had the bare site name as their tab title and no description (bad for search results and for people with many tabs).	<code>generateMetadata</code> on profiles (name + headline) and briefs (title); static titles on the rest; descriptions on pricing, help, directory, for-researchers and home.
8	P2	Brand name hard-coded in 22 places (layout, emails, legal pages, payment descriptions, OG image). A rename (see the launch plan, section 6) would have been error-prone.	<code>lib/brand.ts</code> holds <code>BRAND</code> ; every use reads it.
9	P2	robots.txt still allowed crawling of <code>/ideas</code> , <code>/favorites</code> , <code>/swipe</code> , <code>/disputes</code> , <code>/notifications</code> .	Added to the disallow list.
10	P2	Open-redirect edge in <code>?next=</code> . <code>/login?next=/\evil.com</code> passed the "must start with /" check; browsers treat <code>/\</code> like <code>//</code> .	Rejects <code>/\</code> as well as <code>//</code> . Verified.
11	P2	Over-promising copy. Three places promised pitches "usually within a day" / "within 24 hours", which an empty marketplace can't keep and which invites bad reviews.	Replaced with what actually happens: researchers in the niche are notified the moment the brief goes live.
12	P2	Help FAQ didn't cover the idea board, saved researchers, swipe file, levels, who sees ID photos, taxes, or how to delete an account.	Seven questions added.
13	P2	Proof-screenshot link had no accessible name; "Remove payout method" buttons were indistinguishable to screen readers.	<code>aria-label</code> s added.

Reviewed and found sound

- **Authorisation:** every write goes through a database function that checks the caller, or through row-level security; cross-role pages redirect; another creator cannot open your brief or dispute (404); the CSV export and cron need a session or the secret; the test-payment page only acts on the caller's own payment.
- **Money:** unlocks, refunds, payouts and dispute reversals are atomic with row locks; a triple-click on Confirm unlock charges once; the ledger balances to zero per brief; `hold_hours = 0` behaves (immediate availability, no dispute window).
- **Errors:** email failures are logged and never abort an action; provider errors surface as messages; the webhook returns 500 so the provider retries.
- **Security headers, no `dangerouslySetInnerHTML` except the theme script, no service-role key in client code, signed URLs expire in 5–10 minutes, uploads are type- and size-limited by the storage bucket.**
- **Navigation:** every nav item resolves, exactly one item is active per page, the mobile drawer has all desktop items and closes after navigating, the logo returns to the dashboard inside the app and to the home page outside it.
- **Phone:** no page overflows at 390 px in light or dark mode.

Seen once, not reproduced

A React hydration warning (#418, text mismatch) appeared once on the researcher's brief page during the first crawl, before the stale server was replaced. It did not reproduce in dev mode (which would have shown the exact text) or on

repeated visits. If it shows again, the likely culprits are a time string rendered before `<When>` existed; report the exact page and we'll chase it.

Product gaps found by this review, now closed (follow-up, same day)

#	GAP	WHAT WAS BUILT	VERIFIED BY
A	No rate limiting on login/sign-up/reset.	Attempts are counted in the database (works on serverless hosting, no Redis): 10 password tries per account per 15 minutes, plus loose per-address limits because many Philippine mobile users share one carrier address. Old rows are pruned by the daily job.	SQL tests (window reset, independent keys, service-role only); browser test: 11th login refused even with the right password
B	No self-service account deletion.	Settings → Close account. The database refuses while earnings, a withdrawal, a live brief or an open dispute is attached, otherwise withdraws waiting pitches, deletes ID submissions, payout numbers, saved items and notifications, anonymises the profile, and the auth login is banned and its email freed. Money history stays with the platform.	SQL tests (each blocker, scrubbing, ledger untouched, audit row); browser test: refusal message, confirmation word, logout, login refused
C	No admin two-factor login.	Admins must enrol an authenticator app on first login and enter a code on every login after that (Supabase TOTP, AAL2 checked on every admin page and action). Wrong codes are rate-limited; researchers and creators never see it.	Browser test: forced setup, wrong code refused, right code opens the panel, admin pages blocked before the code
D	Transactional emails were plain text.	Every email now has a branded HTML version (heading, paragraphs, one button for the link) with the old text as fallback.	Build; manual read of the template

Still open (product, not bugs)

- Error monitoring (Sentry) and product analytics (PostHog) are not wired in; see the launch plan.
- Lost-authenticator recovery for admins is manual (another admin removes the factor in the Supabase dashboard). Fine for a two-person team; add backup codes if the admin team grows.